

MODELO DE ENCUESTA INTEGRAL DE CIBERSEGURIDAD

Evaluación de Madurez Organizacional según NIST CSF 2.0, ENS y ACET

Versión: 2.0 | **Fecha:** Enero 2026 | **Ámbito:** Organizaciones España (todas las tamaños) | **Tiempo estimado:** 45-90 minutos

INSTRUCCIONES DE USO

Esta encuesta está estructurada en **8 bloques temáticos** alineados con NIST CSF 2.0 (Gobierno, Identificar, Proteger, Detectar, Responder, Recuperar) + Análisis de Vulnerabilidades + SIEM + Capacitación.

Responda cada pregunta en función de la realidad de su organización. Use las opciones de respuesta proporcionadas. Preguntas de naturaleza técnica pueden delegarse a responsables específicos (CISO, IT Manager, SOC Lead, etc.).

Escala de Respuesta Estándar:

- Sí (Implementado completamente)
- Parcialmente (En implementación/Inconsistente)
- No (No implementado)
- No Aplica (NA)
- Desconoce (DK)

BLOQUE I: GOBIERNO Y ESTRATEGIA (GV)

1.1 Marco de Gobernanza Cibernética

P1.1.1. ¿Dispone su organización de una política de ciberseguridad formalizada, aprobada por la Junta Directiva/Órgano de Gobierno, que define visión, objetivos y roles?

- ☐ Sí (Documentada, revisada anualmente, comunicada a todos los niveles)
- ☐ Parcialmente (Existe pero requiere actualización o comunicación deficiente)
- ☐ No (Sin política formal)
- ☐ NA
- ☐ DK

P1.1.2. ¿Ha designado formalmente un Chief Information Security Officer (CISO) o responsable equivalente con acceso directo a Junta Directiva?

- ☐ Sí (CISO dedicado, reporta a Presidente/CEO, presupuesto independiente)
- ☐ Parcialmente (Responsable de seguridad pero sin acceso directo o autoridad limitada)
- ☐ No (Sin CISO/Responsable)
- ☐ NA
- ☐ DK

P1.1.3. ¿Existe un Comité de Riesgos Cibernéticos que se reúne periódicamente (mínimo trimestral) para revisar indicadores, brechas y estrategia?

- ☐ Sí (Reuniones formales, actas, métricas documentadas, decisiones ejecutadas)
- ☐ Parcialmente (Reuniones irregulares o sin documentación)
- ☐ No (Ausencia de comité)
- ☐ NA
- ☐ DK

P1.1.4. ¿La ciberseguridad está integrada en la estrategia empresarial y planes de transformación digital?

- ☐ Sí (Mencionada en documentos estratégicos, incluida en OKRs/KPIs de negocio)
- ☐ Parcialmente (Considerada pero no formalizada)
- ☐ No (Considerada únicamente como función técnica)
- ☐ NA
- ☐ DK

1.2 Gestión de Riesgos Cibernéticos

P1.2.1. ¿Realiza su organización evaluaciones de riesgos cibernéticos formales anuales (o con mayor frecuencia)?

- ☐ Sí (Metodología FAIR/ISO 27005/NIST 800-30, documentadas, actualizadas)
- ☐ Parcialmente (Evaluaciones informales o irregulares)
- ☐ No (Sin evaluación formal)
- ☐ NA
- ☐ DK

P1.2.2. ¿Ha cuantificado el riesgo cibernético en términos monetarios (€ o probabilidad de pérdida)?

- ☐ Sí (Utiliza FAIR, CASPeA u otro modelo cuantitativo, ALE documentada)
- ☐ Parcialmente (Estimaciones cualitativas)
- ☐ No (Sin cuantificación)
- ☐ NA
- ☐ DK

P1.2.3. ¿Existe un registro formalizado de riesgos cibernéticos que incluye propietario, estado, acciones de mitigación y plazos?

- ☐ Sí (Registro actualizado dinámicamente, accesible a stakeholders)
- ☐ Parcialmente (Existe pero desactualizado o acceso limitado)
- ☐ No
- ☐ NA
- ☐ DK

P1.2.4. ¿Se evalúa la ciberseguridad de proveedores y terceros antes de su contratación?

- ☐ Sí (Cuestionarios NIST CSF, auditorías, cláusulas contractuales)
- ☐ Parcialmente (Evaluación básica)

- ☐ No
- ☐ NA
- ☐ DK

BLOQUE II: IDENTIFICAR (ID)

2.1 Gestión de Activos

P2.1.1. ¿Mantiene su organización un Catálogo Master de Activos Críticos (CMDB) actualizado que incluye hardware, software, datos y servicios?

- ☐ Sí (Automatizado, actualizado en tiempo real, clasificado por criticidad)
- ☐ Parcialmente (Manual, desactualizado, cobertura incompleta)
- ☐ No
- ☐ NA
- ☐ DK

P2.1.2. ¿Ha clasificado sus datos según sensibilidad (p.ej., público, interno, confidencial, RGPD)?

- ☐ Sí (Clasificación formalizada, herramientas DLP, todos los empleados capacitados)
- ☐ Parcialmente (Clasificación en algunos departamentos)
- ☐ No
- ☐ NA
- ☐ DK

P2.1.3. ¿Dispone de un mapa de dependencias entre sistemas (p.ej., qué aplicaciones dependen de qué bases de datos)?

- ☐ Sí (Mapa actualizado, usado para planificación de impacto)
- ☐ Parcialmente (Existe pero desactualizado)
- ☐ No
- ☐ NA
- ☐ DK

2.2 Evaluación de Riesgos de Activos

P2.2.1. ¿Ha identificado y documentado sus activos más críticos para la continuidad del negocio (RTO/RPO definido)?

- ☐ Sí (Análisis de impacto comercial, prioridades claras)
- ☐ Parcialmente (Identificados pero sin priorización formal)
- ☐ No
- ☐ NA
- ☐ DK

P2.2.2. ¿Se evalúan regularmente los activos para identificar configuraciones inseguras o "shadow IT"?

- ☐ Sí (Auditorías técnicas, herramientas CSPM/ASPM, frecuencia mensual+)
- ☐ Parcialmente (Auditorías ocasionales)
- ☐ No

- ☐ NA
- ☐ DK

BLOQUE III: PROTEGER (PR)

3.1 Gestión de Identidad y Acceso (IAM)

P3.1.1. ¿Implementa su organización Multi-Factor Authentication (MFA) para acceso a sistemas críticos?

- ☐ Sí (MFA obligatorio para todos, incluyendo acceso remoto y administrativo)
- ☐ Parcialmente (MFA en algunos sistemas; excepciones documentadas)
- ☐ No
- ☐ NA
- ☐ DK

P3.1.2. ¿Utiliza principios de Zero Trust (verificación continua, least privilege)?

- ☐ Sí (Arquitectura Zero Trust implementada, acceso microsegmentado)
- ☐ Parcialmente (Algunos componentes; transición en progreso)
- ☐ No (Modelo perimetral tradicional)
- ☐ NA
- ☐ DK

P3.1.3. ¿Realiza revisiones periódicas de acceso (access reviews) para validar que los permisos son aún necesarios?

- ☐ Sí (Revisiones formales cada 3-6 meses, certificadas por propietarios)
- ☐ Parcialmente (Revisiones ocasionales)
- ☐ No
- ☐ NA
- ☐ DK

P3.1.4. ¿Se auditan y registran todas las acciones de cuentas administrativas (PAM - Privileged Access Management)?

- ☐ Sí (Solución PAM implementada, sesiones grabadas y audibles)
- ☐ Parcialmente (Registro básico de logs)
- ☐ No
- ☐ NA
- ☐ DK

3.2 Seguridad de Datos

P3.2.1. ¿Se cifran datos sensibles tanto en tránsito como en reposo?

- ☐ Sí (Cifrado TLS 1.2+, AES-256, gestión de claves certificada)
- ☐ Parcialmente (Cifrado en algunos sistemas)
- ☐ No

- ☐ NA
- ☐ DK

P3.2.2. ¿Existe un programa de Data Loss Prevention (DLP) que monitorea y controla exfiltración de datos?

- ☐ Sí (DLP implementado, reglas personalizadas, alertas activas)
- ☐ Parcialmente (Controles básicos)
- ☐ No
- ☐ NA
- ☐ DK

P3.2.3. ¿Se realiza sanitización segura (securely wiping) de datos cuando se descartan dispositivos o dejan de usarse?

- ☐ Sí (Procedimientos documentados, certificados de destrucción)
- ☐ Parcialmente (Prácticas inconsistentes)
- ☐ No
- ☐ NA
- ☐ DK

3.3 Resiliencia de Infraestructura

P3.3.1. ¿Dispone de redundancia y failover automatizado para sistemas críticos?

- ☐ Sí (Múltiples centros de datos, RTO < 4 horas, RPO < 1 hora)
- ☐ Parcialmente (Redundancia parcial)
- ☐ No
- ☐ NA
- ☐ DK

P3.3.2. ¿Implementa segmentación de red (network segmentation/microsegmentación) para aislar sistemas críticos?

- ☐ Sí (Arquitectura segmentada, firewalls internos, control granular)
- ☐ Parcialmente (Segmentación básica)
- ☐ No
- ☐ NA
- ☐ DK

P3.3.3. ¿Se mantiene un programa de hardening de sistemas (deshabilitación de servicios innecesarios, parches críticos)?

- ☐ Sí (Baselines de configuración, evaluaciones periódicas)
- ☐ Parcialmente (Hardening manual inconsistente)
- ☐ No
- ☐ NA
- ☐ DK

3.4 Concienciación y Capacitación en Seguridad

P3.4.1. ¿Todos los empleados reciben capacitación en seguridad anual (mínimo)?

- ☐ Sí (Obligatoria, auditada, >90% tasa de finalización)
- ☐ Parcialmente (Capacitación inconsistente o baja cobertura)
- ☐ No
- ☐ NA
- ☐ DK

P3.4.2. ¿Se realizan simulacros de phishing y se mide el porcentaje de empleados que cae en la trampa (phish-prone %)?

- ☐ Sí (Simulacros mensuales, métricas documentadas, entrenamiento adaptativo para repetidores)
- ☐ Parcialmente (Simulacros ocasionales)
- ☐ No
- ☐ NA
- ☐ DK

P3.4.3. ¿La capacitación en seguridad es específica por rol (ej. desarrolladores reciben OWASP, administrativos reciben RGPD)?

- ☐ Sí (Formación personalizada según responsabilidades)
- ☐ Parcialmente (Capacitación genérica)
- ☐ No
- ☐ NA
- ☐ DK

BLOQUE IV: DETECTAR (DE)

4.1 Monitoreo y Análisis

P4.1.1. ¿Implementa su organización un SIEM (Security Information and Event Management) central?

- ☐ Sí (SIEM empresarial, ingesta multi-fuente, retención >90 días)
- ☐ Parcialmente (SIEM básico o cobertura limitada)
- ☐ No
- ☐ NA
- ☐ DK

P4.1.2. ¿Se recopilan y correlacionan logs de todas las fuentes críticas (endpoints, firewalls, aplicaciones, identidad)?

- ☐ Sí (Cobertura >90%, normalización de eventos)
- ☐ Parcialmente (Cobertura parcial)
- ☐ No
- ☐ NA
- ☐ DK

P4.1.3. ¿Se utiliza threat intelligence (feeds de malware, IoCs) para enriquecer detecciones?

- ☐ Sí (Feeds automatizadas, integración con SIEM/firewalls)
- ☐ Parcialmente (Feeds manuales ocasionales)
- ☐ No
- ☐ NA
- ☐ DK

4.2 Indicadores de Compromiso (IoCs) y Análisis de Comportamiento

P4.2.1. ¿Se monitorean indicadores de compromiso conocidos (IP maliciosas, dominios, hashes)?

- ☐ Sí (Base de datos IoCs actualizada, búsquedas automáticas)
- ☐ Parcialmente (Búsquedas manuales ocasionales)
- ☐ No
- ☐ NA
- ☐ DK

P4.2.2. ¿Se implementa análisis de comportamiento (UEBA - User and Entity Behavior Analytics)?

- ☐ Sí (Líneas base de comportamiento, detección de anomalías automática)
- ☐ Parcialmente (Revisiones manuales ocasionales)
- ☐ No
- ☐ NA
- ☐ DK

4.3 Monitoreo de Integridad de Sistemas (FIM)

P4.3.1. ¿Se monitorean cambios no autorizados en archivos y configuraciones críticas (FIM - File Integrity Monitoring)?

- ☐ Sí (Herramientas FIM, alertas en tiempo real para cambios)
- ☐ Parcialmente (Monitoreo manual)
- ☐ No
- ☐ NA
- ☐ DK

BLOQUE V: RESPONDER (RS)

5.1 Planificación y Coordinación de Respuesta

P5.1.1. ¿Existe un Plan de Respuesta a Incidentes documentado que define roles, responsabilidades, escaladas y procedimientos?

- ☐ Sí (Plan formal, actualizado anualmente, socializado)
- ☐ Parcialmente (Plan básico, desactualizado)
- ☐ No
- ☐ NA
- ☐ DK

P5.1.2. ¿Se ha establecido un equipo de respuesta a incidentes (Incident Response Team) con miembros designados de áreas clave?

- ☐ Sí (Equipo formal, capacitado, disponible 24/7 para críticos)
- ☐ Parcialmente (Equipo informal)
- ☐ No
- ☐ NA
- ☐ DK

P5.1.3. ¿Existe un procedimiento de notificación de brechas que cumple con GDPR, NIS2 y regulaciones locales?

- ☐ Sí (Procedimiento documentado, autoridades identificadas, plazos claros)
- ☐ Parcialmente (Procedimiento básico)
- ☐ No
- ☐ NA
- ☐ DK

5.2 Análisis y Mitigación

P5.2.1. ¿Se investigan todos los incidentes de seguridad siguiendo una metodología estructurada (NIST IR, SANS)?

- ☐ Sí (Forense, cadena de custodia, análisis root cause)
- ☐ Parcialmente (Investigaciones básicas)
- ☐ No
- ☐ NA
- ☐ DK

P5.2.2. ¿Se documentan las lecciones aprendidas tras cada incidente significativo y se implementan mejoras?

- ☐ Sí (Reportes post-mortem, acciones correctivas seguidas)
- ☐ Parcialmente (Documentación ocasional)
- ☐ No
- ☐ NA
- ☐ DK

P5.2.3. ¿Se mide y reporta el Tiempo Medio de Detección (MTTD) y Tiempo Medio de Resolución (MTTR)?

- ☐ Sí (KPIs formales, targets definidos, reportados mensuales)
- ☐ Parcialmente (Métricas informales)
- ☐ No
- ☐ NA
- ☐ DK

5.3 Simulacros y Ejercicios

P5.3.1. ¿Se realizan simulacros de respuesta a incidentes (tabletop exercises) anualmente?

- ☐ Sí (Mínimo anual, cobertura múltiples escenarios, métricas de mejora)
- ☐ Parcialmente (Simulacros ocasionales)
- ☐ No
- ☐ NA
- ☐ DK

BLOQUE VI: RECUPERAR (RC)

6.1 Planificación de Continuidad

P6.1.1. ¿Existe un Plan de Continuidad de Negocio (BCP) y Plan de Recuperación ante Desastres (DRP) formales?

- ☐ Sí (Documentos actualizados, objetivos RTO/RPO definidos, probados)
- ☐ Parcialmente (Planes básicos, desactualizados)
- ☐ No
- ☐ NA
- ☐ DK

P6.1.2. ¿Se realizan pruebas periódicas (mínimo anuales) de recuperación completa de sistemas críticos?

- ☐ Sí (Pruebas de failover completas, restauración verificada)
- ☐ Parcialmente (Pruebas parciales)
- ☐ No
- ☐ NA
- ☐ DK

P6.1.3. ¿Se mantienen backups con la estrategia 3-2-1 (3 copias, 2 medios diferentes, 1 externo)?

- ☐ Sí (Backups automatizados, verificación regular)
- ☐ Parcialmente (Backups inconsistentes)
- ☐ No
- ☐ NA
- ☐ DK

6.2 Comunicación y Aprendizaje

P6.2.1. ¿Se establece una Comunicación de Crisis clara durante y después de un incidente?

- ☐ Sí (Protocolos formales, stakeholders comunicados, transparencia)
- ☐ Parcialmente (Comunicación ad hoc)
- ☐ No
- ☐ NA
- ☐ DK

P6.2.2. ¿Se realiza un análisis sistemático de lecciones aprendidas (post-incident review) y se socializa con la organización?

- ☐ Sí (Reportes formales, mejoras implementadas)
- ☐ Parcialmente (Análisis informal)
- ☐ No
- ☐ NA
- ☐ DK

BLOQUE VII: ANÁLISIS DE VULNERABILIDADES Y PRUEBAS DE PENETRACIÓN

7.1 Gestión de Vulnerabilidades

P7.1.1. ¿Se ejecutan escaneos de vulnerabilidades regularmente (mínimo mensual) en todos los sistemas en alcance?

- ☐ Sí (Escaneos automatizados, baselining, seguimiento de hallazgos)
- ☐ Parcialmente (Escaneos ocasionales)
- ☐ No
- ☐ NA
- ☐ DK

P7.1.2. ¿Se utiliza CVSS (Common Vulnerability Scoring System) y/o EPSS (Exploit Prediction Scoring System) para priorizar remediación?

- ☐ Sí (Scoring automático, priorización dinámica según amenaza)
- ☐ Parcialmente (CVSS sin contextualización)
- ☐ No
- ☐ NA
- ☐ DK

P7.1.3. ¿Se mantiene un registro (Vulnerability Management Program) que rastrea descubrimiento, evaluación, remediación y verificación?

- ☐ Sí (Sistema centralizado, métricas, SLAs por severidad)
- ☐ Parcialmente (Registro manual)
- ☐ No
- ☐ NA
- ☐ DK

P7.1.4. ¿Se han establecido SLAs (Service Level Agreements) para remediación según severidad de vulnerabilidad?

- ☐ Sí (SLAs formales: Crítica <24h, Alta <7 días, Media <30 días)
- ☐ Parcialmente (SLAs genéricos)
- ☐ No
- ☐ NA
- ☐ DK

7.2 Pruebas de Penetración

P7.2.1. ¿Se realizan Pruebas de Penetración (pentests) internas y externas anualmente?

- ☐ Sí (Pentests anuales, por empresa independiente, full-scope)
- ☐ Parcialmente (Pentests ocasionales, alcance limitado)
- ☐ No
- ☐ NA
- ☐ DK

P7.2.2. ¿Se evalúa la madurez del programa de pentests usando un modelo reconocido (CREST, PTES)?

- ☐ Sí (Nivel 3+ en modelo de madurez)
- ☐ Parcialmente (Nivel 1-2)
- ☐ No
- ☐ NA
- ☐ DK

P7.2.3. ¿Se remedia sistemáticamente las vulnerabilidades encontradas en pentests y se verifica la corrección?

- ☐ Sí (Ciclo completo: reporte → remediación → re-test)
- ☐ Parcialmente (Remediación incompleta)
- ☐ No
- ☐ NA
- ☐ DK

P7.2.4. ¿Se incluyen pruebas de phishing, ingeniería social y red team exercises?

- ☐ Sí (Cobertura integral, incluyendo social engineering)
- ☐ Parcialmente (Solo vulnerabilidades técnicas)
- ☐ No
- ☐ NA
- ☐ DK

7.3 Gestión de Configuración Segura

P7.3.1. ¿Se utilizan herramientas de Software Composition Analysis (SCA) para detectar vulnerabilidades en dependencias/librerías?

- ☐ Sí (SCA integrada en pipeline SDLC)
- ☐ Parcialmente (Análisis manual ocasional)
- ☐ No
- ☐ NA
- ☐ DK

P7.3.2. ¿Se aplica Static Application Security Testing (SAST) en el desarrollo de software?

- ☐ Sí (SAST en pipeline CI/CD, bloquea builds críticos)
- ☐ Parcialmente (SAST manual)
- ☐ No

- ☐ NA
- ☐ DK

BLOQUE VIII: GESTIÓN DE INFORMACIÓN Y EVENTOS DE SEGURIDAD (SIEM)

8.1 Infraestructura SIEM

P8.1.1. ¿Qué porcentaje de sus fuentes de seguridad están integradas con el SIEM?

- ☐ Sí (>85% fuentes, incluyendo OT/ICS)
- ☐ Parcialmente (50-85% fuentes)
- ☐ Bajo (<50% fuentes)
- ☐ No hay SIEM
- ☐ DK

P8.1.2. ¿Cuál es el tiempo de latencia promedio de ingestión de logs en el SIEM?

- ☐ Excelente (<1 minuto)
- ☐ Bueno (1-5 minutos)
- ☐ Aceptable (5-30 minutos)
- ☐ Pobre (>30 minutos)
- ☐ DK

P8.1.3. ¿Se retienen logs con capacidad de búsqueda por cuánto tiempo?

- ☐ Excelente (>1 año)
- ☐ Bueno (180-365 días)
- ☐ Aceptable (90-180 días)
- ☐ Pobre (<90 días)
- ☐ DK

8.2 Correlación y Detección

P8.2.1. ¿Cuántas reglas de correlación están activas y ajustadas en el SIEM?

- ☐ Óptimo (>100 reglas, tuning periódico)
- ☐ Bueno (50-100 reglas)
- ☐ Aceptable (20-50 reglas)
- ☐ Pobre (<20 reglas)
- ☐ DK

P8.2.2. ¿Cuál es la tasa de falsos positivos en el SIEM (% de alertas que NO son amenazas reales)?

- ☐ Excelente (<10%)
- ☐ Bueno (10-25%)
- ☐ Aceptable (25-40%)
- ☐ Pobre (>40%)
- ☐ DK

P8.2.3. ¿Cuál es el porcentaje de true positive rate (amenazas detectadas correctamente)?

- ☐ Excelente (>80%)

- ☐ Bueno (60-80%)
- ☐ Aceptable (40-60%)
- ☐ Pobre (<40%)
- ☐ DK

8.3 Workflows y Automatización

P8.3.1. ¿Se automatiza la respuesta a ciertos tipos de alertas (playbooks, SOAR)?

- ☐ Sí (Respuesta automatizada para 30%+ de alertas)
- ☐ Parcialmente (Automatización básica)
- ☐ No
- ☐ NA
- ☐ DK

P8.3.2. ¿Se han integrado herramientas de threat intelligence para enriquecimiento automático de alertas?

- ☐ Sí (Feeds integradas, contexto automático)
- ☐ Parcialmente (Integración manual)
- ☐ No
- ☐ NA
- ☐ DK

8.4 Indicadores de Rendimiento SIEM

P8.4.1. ¿Se monitorea el Mean Time to Detect (MTTD - tiempo promedio hasta detección)?

- ☐ Sí (Métrica formal, target <2 horas)
- ☐ Parcialmente (Métrica informal)
- ☐ No
- ☐ NA
- ☐ DK

P8.4.2. ¿Se reportan alertas-a-incidentes (alert-to-incident ratio)?

- ☐ Sí (Métrica formal, objetivo es reducir false positives)
- ☐ Parcialmente (Métrica informal)
- ☐ No
- ☐ NA
- ☐ DK

P8.4.3. ¿Se evalúa regularmente la efectividad del SIEM y se ajustan reglas según resultados?

- ☐ Sí (Revisión mensual, optimizaciones continuas)
- ☐ Parcialmente (Revisión ocasional)
- ☐ No
- ☐ NA
- ☐ DK

BLOQUE IX: CAPACITACIÓN EN SEGURIDAD DE EMPLEADOS

9.1 Programa de Concienciación General

P9.1.1. ¿Cuál es la tasa de finalización de capacitación en seguridad de la organización?

- ☐ Excelente (>95%)
- ☐ Bueno (90-95%)
- ☐ Aceptable (80-90%)
- ☐ Pobre (<80%)
- ☐ DK

P9.1.2. ¿Se actualiza el contenido de capacitación según nuevas amenazas emergentes?

- ☐ Sí (Actualización trimestral mínimo)
- ☐ Parcialmente (Actualización anual)
- ☐ No (Contenido estático)
- ☐ NA
- ☐ DK

P9.1.3. ¿Se utilizan múltiples formatos de capacitación (vídeos, juegos, micro-learning, presencial)?

- ☐ Sí (Variedad de formatos, engagement alto)
- ☐ Parcialmente (1-2 formatos)
- ☐ No (Un único formato)
- ☐ NA
- ☐ DK

9.2 Indicadores de Efectividad de Capacitación

P9.2.1. ¿Cuál es el porcentaje de empleados que falla en simulacros de phishing (phish-prone %)?

- ☐ Excelente (<3%)
- ☐ Bueno (3-10%)
- ☐ Aceptable (10-20%)
- ☐ Pobre (>20%)
- ☐ DK

P9.2.2. ¿Qué porcentaje de empleados reporta proactivamente emails de phishing o sospechas de seguridad?

- ☐ Excelente (>50%)
- ☐ Bueno (30-50%)
- ☐ Aceptable (10-30%)
- ☐ Pobre (<10%)
- ☐ DK

P9.2.3. ¿Se mide la retención de conocimiento mediante post-training assessments o quizzes?

- ☐ Sí (Assessment formal, score mínimo requerido)
- ☐ Parcialmente (Assessment opcional)

- ☐ No
- ☐ NA
- ☐ DK

9.3 Capacitación Especializada por Rol

P9.3.1. ¿Reciben capacitación especializada los desarrolladores en OWASP Top 10, SSDLC?

- ☐ Sí (Capacitación anual especializada)
- ☐ Parcialmente (Capacitación genérica)
- ☐ No
- ☐ NA
- ☐ DK

P9.3.2. ¿Reciben capacitación especializada los administradores en hardening, PAM y auditoria?

- ☐ Sí (Capacitación anual especializada)
- ☐ Parcialmente (Capacitación genérica)
- ☐ No
- ☐ NA
- ☐ DK

P9.3.3. ¿Se capacita periódicamente a personal de Junta/Ejecutivo en gobernanza de ciberseguridad y riesgos?

- ☐ Sí (Capacitación anual, adapta al contexto de negocio)
- ☐ Parcialmente (Capacitación ocasional)
- ☐ No
- ☐ NA
- ☐ DK

9.4 Indicadores de Madurez de Capacitación

P9.4.1. ¿Se correlaciona la participación en capacitación con reducción de incidentes?

- ☐ Sí (Análisis correlativo documentado, ROI demostrado)
- ☐ Parcialmente (Análisis informal)
- ☐ No
- ☐ NA
- ☐ DK

P9.4.2. ¿Se identifican departamentos/roles de alto riesgo y se proporciona capacitación adicional?

- ☐ Sí (Segmentación de entrenamiento por riesgo)
- ☐ Parcialmente (Entrenamiento genérico)
- ☐ No
- ☐ NA
- ☐ DK

PREGUNTAS FINALES DE CONTEXTO

P10.1. ¿Cuál es el tamaño de su organización?

- ☐ Micro (<10 empleados)
- ☐ Pequeña (10-50)
- ☐ Mediana (50-250)
- ☐ Grande (250-1.000)
- ☐ Muy Grande (>1.000)

P10.2. ¿A qué sector pertenece? (Seleccione uno)

- ☐ Energía / Suministros
- ☐ Telecomunicaciones
- ☐ Financiero / Seguros
- ☐ Sanitario
- ☐ Administración Pública
- ☐ Manufactura / Industrial
- ☐ Tecnología / IT
- ☐ Retail / Comercio
- ☐ Logística / Transporte
- ☐ Educación
- ☐ Otro: _____

P10.3. ¿Ha sufrido algún ciberataque significativo en los últimos 3 años?

- ☐ Sí (Indique tipo: _____)
- ☐ No
- ☐ No sabe / No recuerda

P10.4. ¿Cuál es aproximadamente su presupuesto anual de ciberseguridad?

- ☐ <€50.000
- ☐ €50.000 - €200.000
- ☐ €200.000 - €500.000
- ☐ €500.000 - €2M
- ☐ >€2M
- ☐ Desconoce

P10.5. ¿Cuántos profesionales equivalentes a tiempo completo dedica a ciberseguridad?

- ☐ 0-1 FTE
- ☐ 1-3 FTE
- ☐ 3-5 FTE
- ☐ 5-10 FTE
- ☐ >10 FTE

P10.6. ¿Está su organización sujeta a NIS2, GDPR, ENS, o normativa sectorial específica?

- ☐ Sí, indique cuál: _____

- [] No
- [] Desconoce

FIN DE LA ENCUESTA

Gracias por completar esta evaluación. Los resultados serán procesados para generar un Índice de Madurez Cibernética (IGM) y reporte ejecutivo personalizado.